



ISC 互联网安全大会



360 互联网安全中心

移动终端安全势道术

李雨航

华为终端安全首席架构师/移动安全联盟副理事长

2018 ISC 互联网安全大会 中国·北京

Internet Security Conference 2018 Beijing·China

(原中国互联网安全大会)

移动终端业务趋势

12年一轮回，手机即将面临新一代体验革命——智慧互联网



一代

1983年
模拟



通话

大哥大

通话
键盘

二代

1995年
数字



工具

功能机

通话+短信+小工具
键盘+彩屏

三代

2007年
移动互联网



助手

智能手机

泛服务APP化
大屏+触摸

四代

2019~2020年
智慧互联网



分身

智慧手机

现实/数字世界无缝交织
人工智能+自然交互

终端产业发展的两条主线：交互模式+信息服务模式

ZERO TRUST SECURITY

IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China

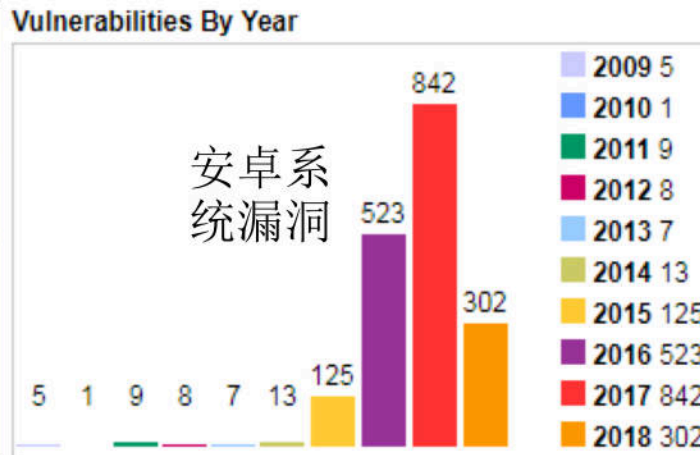
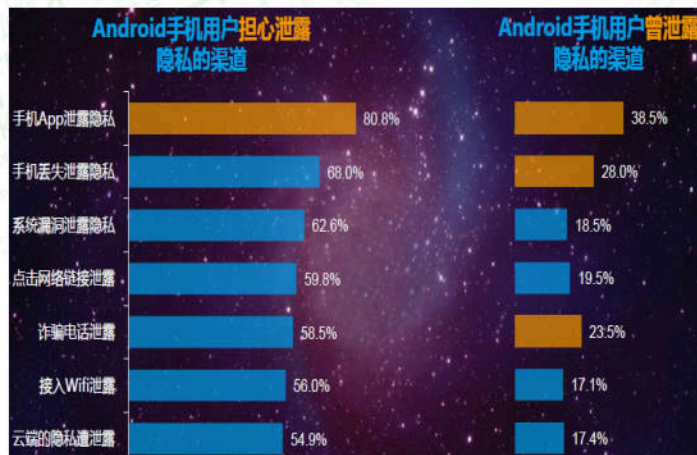
移动终端安全趋势



ISC 互联网安全大会

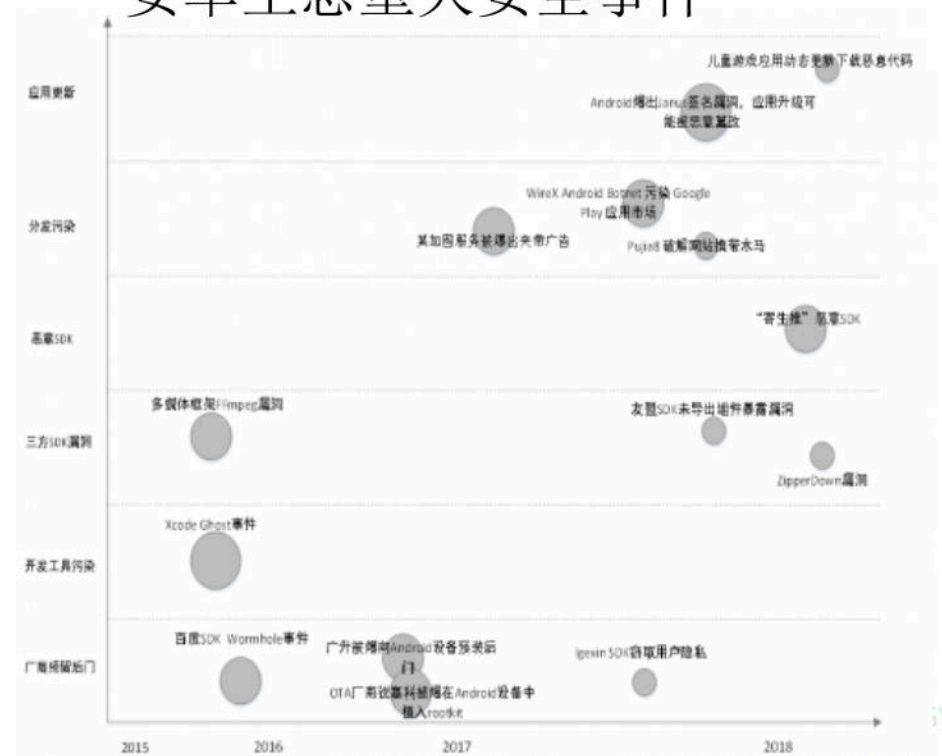


360 互联网安全中心



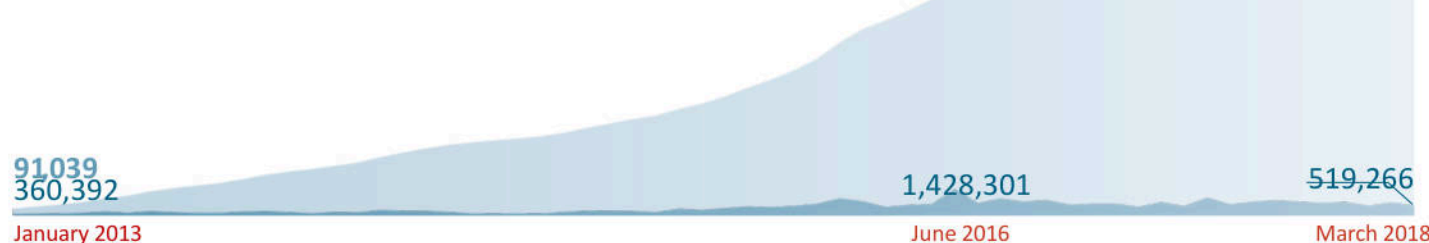
应用一定不可靠，系统一定会攻破，单点一定有短板

安卓生态重大安全事件



The number of Android malware programs known to AV-TEST

Total number of Android samples
New Android samples per month



恶意软件总数逐年加倍增长（至2018年Q1）

ZERO TRUST SECURITY

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China

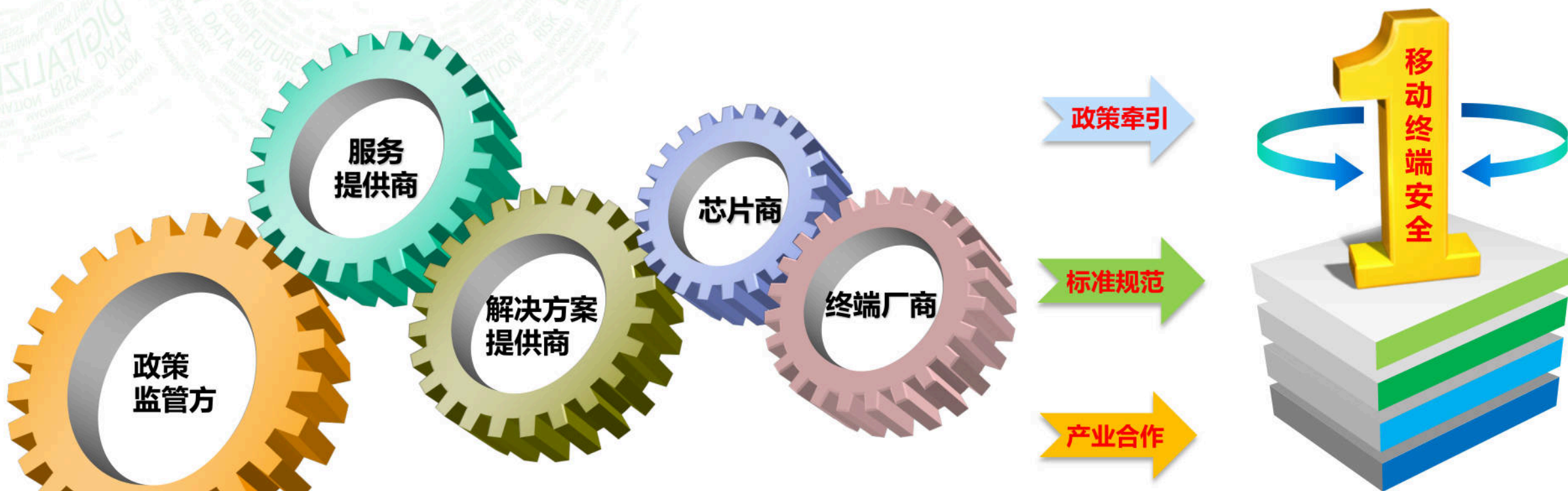
Mobile Threat Actor 移动威胁者

- 个人：黑客，内鬼，他人（窥探隐私）
- 团伙：恶意APP开发商，电信诈骗团伙，勒索敲诈团伙，木马病毒团伙
- 组织：黑产组织，恐怖组织，不良厂商（植广告、收集滥用数据），不良渠道商（灌装）
- 国家：敌对政府，网军，间谍机构



1. 刷机&篡改：在手机启动之前或之中被软硬灌装与恶意植入代码
2. 系统进程漏洞：被利用造成入侵/提权/Root等危害
3. 内存越界整数溢出攻击：被利用造成入侵/提权/Root等危害
4. 内核重复释放攻击：被利用造成入侵/提权/Root等危害
5. ROP/JOP攻击：被利用造成入侵/提权/Root等危害
6. ROD/数据流攻击：被利用造成入侵/提权/Root等危害
7. 芯片漏洞：被利用造成入侵/提权/Root等危害
8. 寄存器攻击：被攻击造成数据泄露等危害
9. 高速缓存攻击：被攻击造成数据泄露等危害
10. 侧信道攻击：被攻击造成数据泄露等危害
11. 通讯攻击：伪基站和恶意热点/设备通过WIFI/蓝牙/蜂窝网络干扰或破坏手机功能
12. APP缺乏管控：通知栏凌乱、悬浮干扰、权限授予、应用随意调用安装器、后台随意下载、滥用Hidden API，获取用户数据，插入广告，恶意吸费，植入木马，后台调用相机/Mic/位置监听
13. 伪装篡改App：隐私数据遭窃取
14. 勒索软件：加密用户数据索取解密费
15. 蠕虫病毒：破坏正常功能
16. BAT AI隐私数据收集滥用：隐私数据遭不当使用
17. 丢失手机/忘记锁屏密码：失去功能，数据遭窃取
18. 密码暴力破解攻击：系统被入侵，数据遭窃取
19. 不健壮解锁与身份认证算法协议：系统被入侵，数据遭窃取
20. 生物特征仿冒攻击：失去手机后系统被入侵，数据遭窃取

解决之道：安全是整个移动产业的共同挑战，需要产业链合作



移动终端安全涉及产业链各环节，是复杂、长期的系统工程，目标是构建消费者对于移动终端的信任，促进良性、共赢的发展。

ZERO TRUST SECURITY

安卓绿色联盟实践



成立背景

由阿里巴巴、百度、华为、腾讯、网易五家企业共同发起

为了解决由安卓系统的开放性、碎片化导致的应用兼容性、稳定性、安全性与整体感知等方面存在的问题。



联盟定位

中国首个致力于提升安卓应用体验的联合组织。



联盟宗旨

- 开放创新、合作共赢
- 共同构建中国安卓绿色应用环境，打造安全、可靠、值得信赖、健康的应用生态体系，不断给用户带来极致的应用体验。



基于绿盟平台，
建立安全标准，
统一行为规范，
共建安全生态



移动安全联盟实践



移动安全联盟
Mobile Security Alliance

中国信通院（泰尔终端实验室为代表）、华为、360、北京大学、Vivo等共同发起

联盟主旨

联盟立足于搭建移动互联网安全的合作与促进平台，聚集信息通信界的中坚力量及相关机构，服务企业，支撑政府决策，推进移动互联网、移动设备安全发展，为实施《网络安全法》和推动“互联网+”发展提供必要支撑。

联盟任务

着力聚集产业生态各方力量，联合开展移动安全技术、标准和产业研究，共同探索移动安全的新模式和新机制，维护行业公平，推进技术、产业与应用研发，开展试点示范，广泛开展国际合作，形成全球化的合作平台。

工作内容

（一）开展移动设备、移动应用安全需求、网络、数据、产业等架构及技术研究；

（二）开展移动安全标准规范前期研究及标准化推进；

（三）开展移动安全测试验证等，推动技术产品及应用创新；

（四）开展移动安全的试点示范，推动相关设备和应用的认证工作；

（五）开展移动安全国际国内交流与合作。

- 终端应用软件安全与质量要求实施指南
- 设备数据采集规范
- 设备唯一标识安全技术要求
- 终端反欺诈安全技术要求

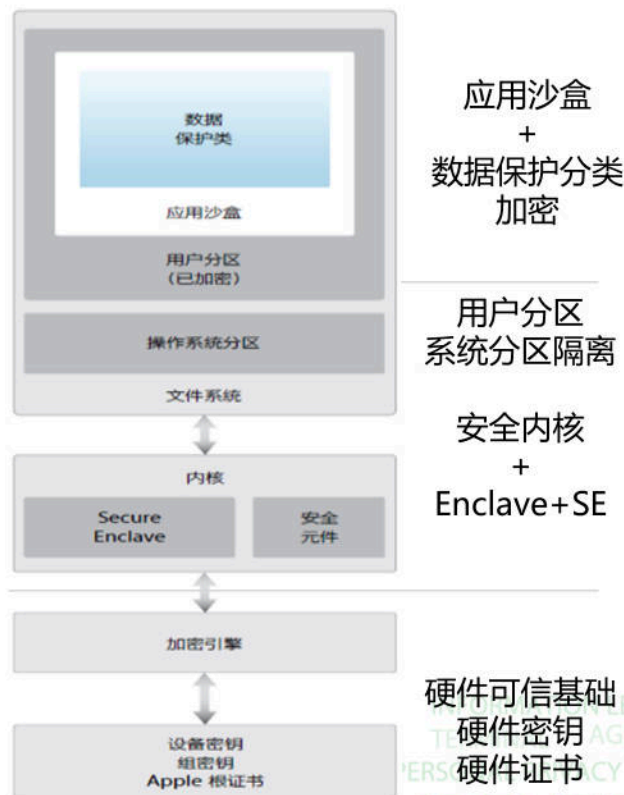
ZERO TRUST SECURITY

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China

iOS 12安全新功能:

- 更便捷的双重认证: iOS 12 中加入了自动填写认证码的功能, 使双重认证更容易使用。
- 广告追踪减少: 目前在 iOS 上的 Safari, 已经会阻挡第三方 cookie 以及特定网站中超过 30 天的第一方 cookie, 对用户隐私已有一定保障。不过在 iOS 12 当中, Safari 还会阻挡网页中的评论区块以及社交媒体的分享按钮。另外在 iOS 的 Safari 还会阻挡追踪器识别你的装置。因为只要追踪代码可以识别你的装置, 即使不知道用户是谁, 也可以建构该装置持有者的专属浏览模式。
- 强度更高的密码: 当用户需要申请帐户时, 密码是账号安全的第一道防线。而 Apple 表示在 iOS 12 当中, 他们会开始建议用户使用强度更高的密码, 然而目前仍不知道这项功能会如何作用。另外还有一项新功能, 就是只要用户有将密码储存在 Safari 中, 当用户于两个以上不同的帐户使用相同的密码时, 系统就会发出警告提示, 建议用户更改密码。
- 加密群组视讯: FaceTime 会在 iOS 12 当中加入用户期待已久的群组视讯功能, 当然这些视讯内容都会进行加密, 即使 Apple 也没办法观看你的 FaceTime 视讯通话。
- 装置破解的防护: 无论是不法之徒或是执法单位, 若是想要破解 iPhone, 都得使用暴力破解的方式, 即是不断尝试各种密码来进行登入。然而在 iOS 12 里, 假设一台 iPhone 有 1 个小时以上没有进行解锁, 那么 Lightning 端口就会变成只能进行充电, 而无法进行其他链接, 换句话说, 就没办法用外部设备来进行暴力破解。

底层结合Enclave/SEP, 以硬件可信为基础, 上层应用生态管控



iOS系统安全架构

安卓P版本安全新功能：

提升指纹验证功能：改进生物特征安全模型，给指纹验证对话框提供标准化界面布局。

签名机制v3：增加了密钥轮转的支持,可以轻松对一个新的证书进行签名，并与APK文件进行绑定。

默认支持HTTPS：第三方开发者可以为自己的App开启HTTPS。

保护确认API：App可以使用ConfirmationPrompt类来向用户显示确认弹窗，并询问他们是否允许相应操作，这种机制既保证了对话框的正确显示，又保护了用户的输入数据。

硬件安全模块：支持StringBox Keymaster的功能，这个功能模块拥有自己的CPU、安全存储区域以及一个真实随机数生成器，它还可以保护App的数据包不被篡改。

外围设备后台策略：App将无法直接访问设备的麦克风、摄像头和传感器。当App尝试在后台访问这些组件时，用户将收到通知消息。

备份数据加密：整个加密过程都将在客户端设备上完成。

云侧

Google安全服务

Saftynt 服务

设备管理服务

应用层

Saftynt (GMS)

SafetyNet

Verify Apps

Safe Browsing

reCAPTCHA 人机交互认证

Device Manager
远程设备管理

Lock Screen

fingerprint

Smart lock

Auto fill

框架层

Keystore

Crypto API

FRP服务

DRM

BoringSSL

permission

Encryption (FBE/FDE)

sandbox

APK signature

AFW

内核

Verified Boot

ASLR/PXN

Trusty

Seccomp

SELinux

积极参与业界安全标准的制定和安全认证测试

- 在人民银行科技司指导下，华为作为主要贡献方，制订了《移动终端支付可信环境》，经过多轮审查，在2017.11正式发布



- 国内手机首家通过央行和银联移动支付安全认证

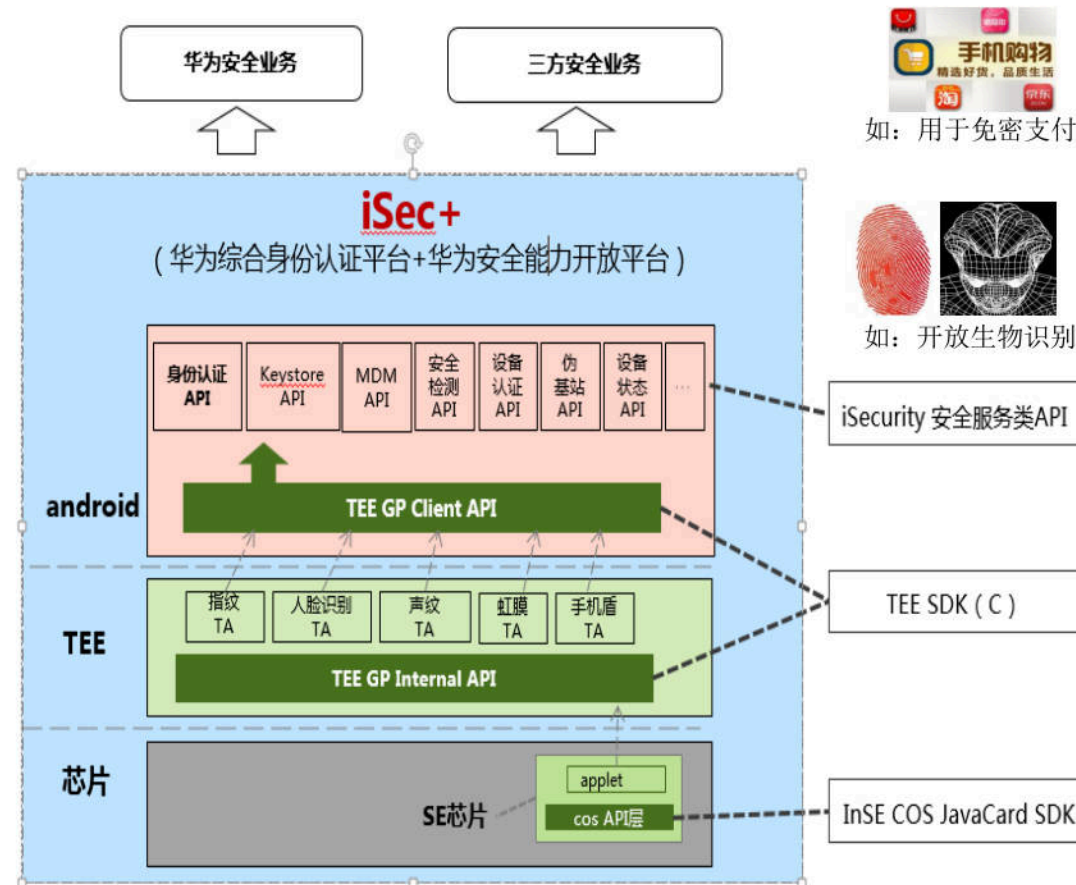


- 通过华为“EMUI 开放安全能力”，支撑各行业的业务发展，提升业务安全能力。

云

端

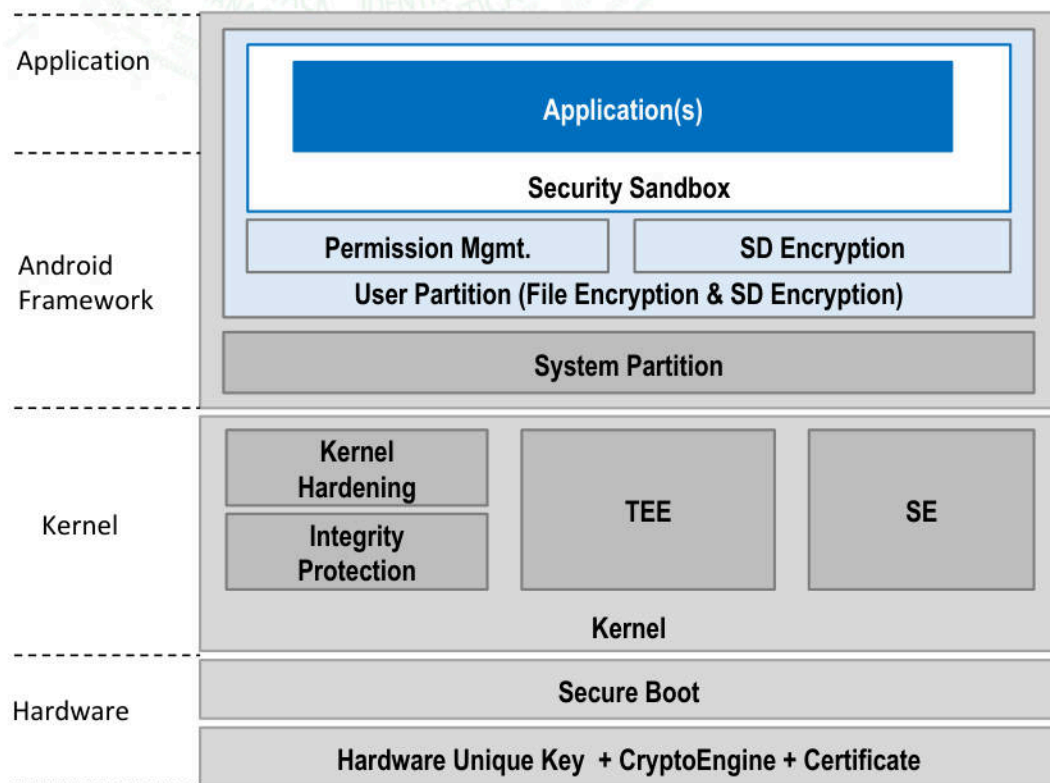
芯



华为安全实践（续）- 业界领先的核心技术能力



华为EMUI总体安全架构



华为是业界为数不多具有从芯片开始到TEE OS以及上层全栈安全能力的厂商之一，详细信息请下载：**EMUI 8.0 安全技术白皮书**

身份认证

数据安全

应用安全

系统安全

芯片安全

- 硬件芯片：安全启动、硬件加解密引擎、设备唯一密钥HUK、设备证明密钥对、TEE、安全存储、指纹认证
- 系统安全：完整性保护、SELinux访问控制、内核地址空间布局随机化、系统软件更新
- 数据安全：锁屏密码保护、文件系统加密、SD卡加锁和加密、安全擦除
- 应用安全：应用签名、应用沙箱、运行时内存保护、安全输入、应用威胁检测、恶意网址检测、流量管理
- 网络安全：VPN、SSL/TLS、WPA/WAP2、安全Wi-Fi检测
- 通信安全：防伪基站、骚扰拦截、短信加密、设备互联安全性
- 支付安全：Huawei Pay、手机盾、支付保护中心、验证码短信保护
- 互联网云服务安全：华为帐号、扫描登录、帐号保护、华为帐号消息、HiCloud、基于帐户的密钥、HiCloud云备份
- 设备管理：查找我的手机、激活锁、MDM移动设备管理、移动设备管理API、设备证书授权
- 隐私保护：权限管理、位置服务、通知管理、应用锁、文件保密柜、隐私空间

ZERO TRUST SECURITY

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China

移动终端安全的未来 - 人才培养



ISC 互联网安全大会



360 互联网安全中心

- 3 万余人: 近年我国高校教育培养的信息安全专业人才
- 70 万人: 而网络安全人才总需求量, 缺口高达95%
- 140 万: 预计 2020 年相关人才需求(将以每年1.5 万人的速度递增)

随着移动互联网主导地位不断强化, 移动互联网安全成为网络安全关键领域, 需要产学合作培育人才。

例如华为终端安全岗位(芯片, 系统, 应用, 数据, 身份等安全领域)大量缺口:

安全架构师, 安全技术专家, 安全攻防专家, 安全工程师, PKI专家, 隐私技术专家。。。

自荐推荐联系方式: yuhang.yale.li@huawei.com



ZERO TRUST SECURITY

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China



ISC 互联网安全大会



360 互联网安全中心

谢谢！

2018 ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
(原中国互联网安全大会)